UNIVERSIDAD PERUANA CAYETANO HEREDIA

FACULTAD DE CIENCIAS E INGENIERÍA

Taller 15

SISTEMAS OPERATIVOS



Grupo 4

Integrantes:

Hernandez Lopez, Justin Brayton

Rebatta Jeri, Patricia del Pilar

Medina Rojas, Martha Sofía

Vega Sanchez, Jimena Natalia

Profesor:
Roberto Eduardo Burga Montañez

Actividad 1: Identificación de activos de información en Linux

Objetivo: Reconocer activos críticos y clasificarlos.

Instrucciones

1. Crear la siguiente estructura:
    - mkdir -p empresa/{finanzas,rrhh,produccion}
    - touch empresa/finanzas/planilla.xlsx
    - touch empresa/rrhh/empleados.csv
    - touch empresa/produccion/clientes.db
2. Identificar:
    - Activo de información.
    - Propietario.
    - Nivel de confidencialidad.
    - Riesgo asociado.

Evidencia en GitHub

1. Crear un archivo:
    - nano inventario_activos.md

Subirlo al repositorio:

- git add
- git commit -m "Inventario de activos"
- git push

Inventario de activos

Activo de información	Ubicación	Propietario	Confidencialidad	Riesgo asociado
Planilla de salarios (planilla.xlsx)	Finanzas	Área de Finanzas	Alta	Acceso no autorizado, filtración de salarios y datos bancarios.
Registro de empleados (empleados.csv)	RRHH	Recursos Humanos	Alta	Exposición de datos personales y robo de identidad.
Base de datos de clientes (clientes.db)	Producción	Área de Producción	Alta	Pérdida, modificación o acceso no autorizado a información de

Clasificación de confidencialidad

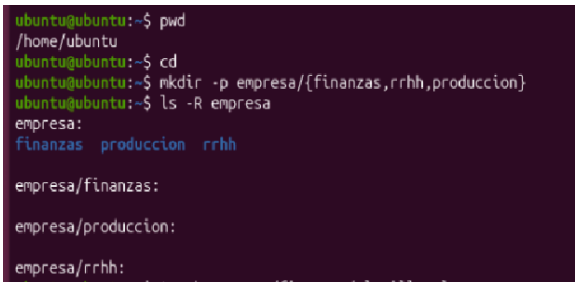
- **Alta:** Información sensible que solamente debe ser accesible por personal autorizado.
- **Media:** Información interna que puede compartirse dentro de la organización con ciertas restricciones.
- **Baja:** Información pública que no representa un riesgo significativo si se divulga.

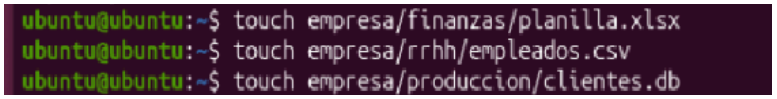
Riesgos identificados

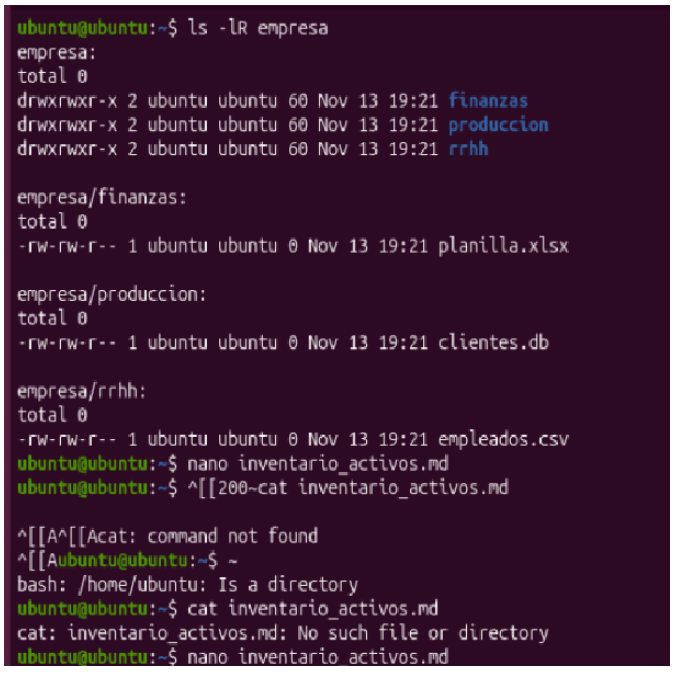
- Filtración de información confidencial.
- Acceso no autorizado a archivos.
- Modificación o eliminación de información.
- Pérdida de datos importantes para la empresa.

Conclusión

La identificación de activos de información permite reconocer los recursos más importantes de una organización y los riesgos que pueden afectarlos. Clasificar estos activos facilita establecer medidas de seguridad para proteger la confidencialidad, integridad y disponibilidad de la información.







```
ubuntu@ubuntu:~$ cat inventario_activos.md
# INVENTARIO DE ACTIVOS DE INFORMACIÓN

## 1. Objetivo

Identificar y clasificar los activos de información de la empresa,
considerando su propietario, nivel de confidencialidad y riesgos asociados.

## 2. Inventario de activos

| Activo | Propietario | Confidencialidad | Riesgo asociado |
|---|---|---|---|
| planilla.xlsx | Área de Finanzas | Alta | Exposición de sueldos y datos bancarios. |
| empleados.csv | Área de Recursos Humanos | Alta | Divulgación de datos personales y robo de identidad. |
| clientes.db | Área de Producción | Alta | Acceso no autorizado y filtración de información. |

## 3. Clasificación de confidencialidad

- Alta: Información sensible que solo debe ser accesible
  por personal autorizado.
- Media: Información interna de la empresa.
- Baja: Información pública que no requiere restricciones especiales.

## 4. Riesgos identificados

- Acceso no autorizado a información confidencial.
- Robo o filtración de datos personales.
- Pérdida o modificación de información importante.
- Divulgación de información financiera.

## 5. Conclusión
```

```
ubuntu@ubuntu:~$ ls -R
.:
Desktop     Music      Templates  inventario_activos.md
Documents   Pictures   Videos     inventario_activos.md0
Downloads   Public     empresa    snap

./Desktop:
ubuntu-desktop-bootstrap_ubuntu-desktop-bootstrap.desktop

./Documents:

./Downloads:

./Music:

./Pictures:

./Public:

./Templates:

./Videos:

./empresa:
finanzas  produccion  rrhh

./empresa/finanzas:
planilla.xlsx
```

```
ubuntu@ubuntu:~$ git status
Command 'git' not found, but can be installed with:
sudo apt install git
ubuntu@ubuntu:~$ sudo apt install git
Installing:
  git

Installing dependencies:
  git-man  liberror-perl

Suggested packages:
  git-doc  git-email  git-gui  gitk  gitweb  git-cvs  git-svn

Summary:
  Upgrading: 0, Installing: 3, Removing: 0, Not Upgrading: 0
  Download size: 5453 kB
  Space needed: 28.4 MB / 1510 MB available
```



Actividad 2: Auditoría de permisos de acceso

Objetivo: Verificar controles de acceso.

Escenario

Asignar permisos incorrectos:

- chmod 777 empresa/finanzas/planilla.xlsx
- chmod 777 empresa/rrhh/empleados.csv

Tarea

Los estudiantes deberán:

- ls -l empresa/finanzas
- ls -l empresa/rrhh

Responder:

- ¿Existe incumplimiento?
- ¿Qué riesgo genera?
- ¿Qué control ISO 27001 aplica?

Corregir:

- chmod 640 empresa/finanzas/planilla.xlsx
- chmod 640 empresa/rrhh/empleados.csv

Evidencia

Capturas y reporte en GitHub.



- ¿Existe incumplimiento?

  Sí, existe un incumplimiento de los permisos de seguridad de la información, porque los archivos financieros y de recursos humanos tienen permisos 777. Estos permisos permiten que cualquier usuario del sistema pueda leer, modificar y ejecutar los archivos.

- ¿Qué riesgo genera?

  Los riesgos principales son:

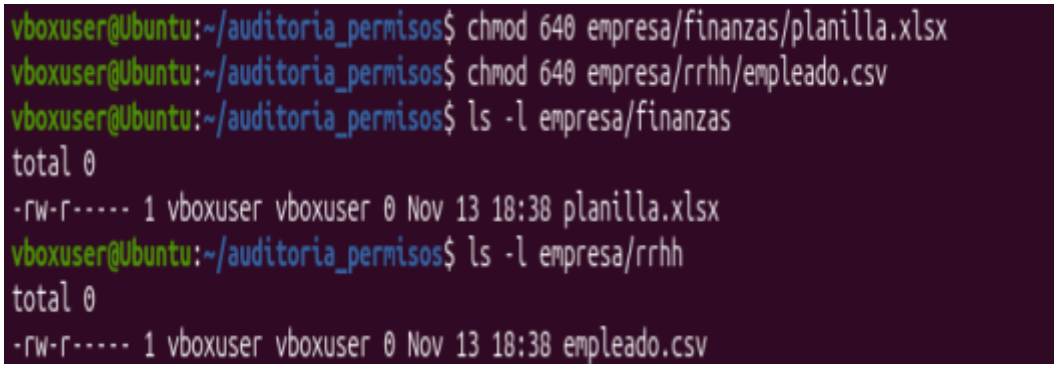
  - Exposición de información confidencial de los empleados.
  - Acceso no autorizado a información financiera.
  - Modificación o eliminación de datos importantes.
  - Pérdida de confidencialidad e integridad de la información.
  - Posibles incidentes de seguridad por acceso indebido.

- ¿Qué control ISO 27001 aplica?

  Puedes relacionarlo con la norma ISO/IEC 37001:2022:

  - A.5.15 - Control de acceso: establecer reglas para controlar el acceso a la información.
  - A.5.18 - Derechos de acceso: asignar, revisar y retirar permisos de acceso según corresponda.
  - A.8.3 - Restricción de acceso a la información: limitar el acceso a la información y a los recursos asociados de acuerdo con las políticas de acceso.

  Estos controles del Anexo A son aplicables a la situación que estás auditando.



Actividad 3: Gestión de hallazgos de auditoría

Objetivo: Elaborar no conformidades.

Hallazgos simulados

1. Contraseñas compartidas.
2. Archivos sensibles con permisos 777.
3. Usuarios inactivos sin eliminar.

Trabajo

Crear:

- nano hallazgos_auditoria.md

Formato:

Hallazgo	Evidencia	Riesgo	Recomendación

Publicar en GitHub.

Gestión de Hallazgos de Auditoría (hallazgos_auditoria.md)

Curso: Sistemas Operativos – Unidad 3 (Semana 15: Implementación del SGSI e ISO/IEC 27001)

Objetivo: Elaborar no conformidades de auditoría a partir de hallazgos de seguridad en el servidor Linux corporativo.

Controles ISO/IEC 27001 evaluados: A.5.15 (Control de acceso), A.5.16 (Gestión de identidades), A.5.17 (Información de autenticación), A.5.18 (Derechos de acceso) y A.8.3 (Restricción del acceso a la información).

1. Matriz de Hallazgos y No Conformidades de Auditoría

A continuación se presenta la tabla oficial de hallazgos simulados durante la auditoría del Sistema de Gestión de Seguridad de la Información (SGSI) sobre el servidor Ubuntu:

Hallazgo	Evidencia	Riesgo	Recomendación
1. Contraseñas compartidas entre varios usuarios	Registros en /var/log/auth.log y comando who / last muestran conexiones simultáneas a la misma cuenta desde distintas direcciones IP y terminales (pts/0, pts/1), además de entrevistas al personal que confirman el uso grupal de una sola credencial.	**Alto (Pérdida de Trazabilidad y No Repudio):** Imposibilidad de identificar al autor real ante un incidente, robo de información o modificación maliciosa (amenaza interna / *insider threat*), incumpliendo el control ISO 27001 A.5.17.	Asignar cuentas nominales e individuales para cada trabajador (sudo adduser), prohibir el préstamo de credenciales en politica_seguridad.md, forzar la rotación de contraseñas (sudo chage -d 0 usuario) y activar Autenticación Multifactor (MFA).
2. Archivos sensibles con permisos 777 (rwxrwxrwx)	Al ejecutar ls -l empresa/finanzas y ls -l empresa/rrhh se observa -rwxrwxrwx sobre activos críticos como planilla.xlsx y empleados.csv, otorgando lectura, escritura y ejecución a cualquier usuario del sistema (others).	**Crítico (Fuga y Alteración de Datos):** Cualquier usuario no autorizado o proceso comprometido puede leer datos confidenciales (Confidencialidad), alterar planillas o borrar registros (Integridad y Disponibilidad), vulnerando el principio del menor privilegio (ISO 27001 A.8.3).	Aplicar de inmediato permisos restrictivos bajo el modelo DAC/RBAC con chmod 640 empresa/finanzas/planilla.xlsx y chmod 640 empresa/rrhh/empleados.csv, asignando propietarios y grupos específicos mediante chown.
3. Usuarios inactivos sin eliminar ni deshabilitar	La inspección de /etc/passwd, /etc/shadow y el comando lastlog evidencia cuentas de excolaboradores o practicantes que no registran inicios de sesión desde hace más de 90 días pero conservan acceso activo y pertenencia a grupos del sistema.	**Alto (Superficie de Ataque Expuesta):** Las cuentas huérfanas o abandonadas pueden ser comprometidas mediante ataques de fuerza bruta o utilizadas por atacantes internos para operar sin levantar sospechas, incumpliendo el control ISO 27001 A.5.18.	Bloquear de inmediato las cuentas inactivas (sudo usermod -L usuario_inactivo), revocar sus permisos, eliminar las cuentas que ya no requieran retención (sudo deluser --remove-home usuario) y establecer revisiones mensuales de cuentas.

2. Desarrollo Técnico de las No Conformidades (Detalle para el Auditor)

No Conformidad NC-01: Uso de Credenciales Compartidas

- **Clasificación:** No Conformidad Mayor (Incumplimiento de ISO/IEC 27001 Control A.5.16 y A.5.17).
- **Pilar de seguridad vulnerado:** Confidencialidad, Integridad y principio de **Responsabilidad / Trazabilidad** (Auditoría).
- **Verificación técnica en Linux:**
  - Consulta de sesiones concurrentes con la misma identidad desde distintas estaciones: who y last -a -n 15.
- **Acción correctiva en terminal:**
  - Crear cuentas individuales por rol (sudo adduser empleado2), invalidar la contraseña compartida (sudo passwdadministrador / sudo passwd empleado) y obligar al cambio en el próximo inicio de sesión (sudo passwd -e usuario).

No Conformidad NC-02: Permisos Excesivos (**chmod 777**) en Activos Críticos

- **Clasificación:** No Conformidad Mayor (Incumplimiento de ISO/IEC 27001 Control A.5.15 y A.8.3).
- **Pilar de seguridad vulnerado:** Confidencialidad e Integridad de la información financiera y de recursos humanos.
- **Verificación técnica en Linux:**
  - Búsqueda automatizada de archivos con permisos 777 dentro del directorio corporativo: find empresa/ -type f -perm 0777 -ls.
- **Acción correctiva en terminal:**
  - Restablecer el principio del menor privilegio aplicando permisos 640 (-rw-r-----):
    - chmod 640 empresa/finanzas/planilla.xlsx
    - chmod 640 empresa/rrhh/empleados.csv
    - chmod 640 empresa/produccion/clientes.db

No Conformidad NC-03: Cuentas de Usuario Inactivas Activas en el Sistema

- **Clasificación:** No Conformidad Menor / Mayor según privilegios asociados (Incumplimiento de ISO/IEC 27001 Control A.5.18).
- **Pilar de seguridad vulnerado:** Confidencialidad (aumento del vector de intrusión por credenciales olvidadas).
- **Verificación técnica en Linux:**
  - Revisión de la fecha del último inicio de sesión de todas las cuentas del servidor: lastlog y consulta de cuentas habilitadas en /etc/passwd (awk -F: '$3 >= 1000 {print $1, $3, $7}' /etc/passwd).
- **Acción correctiva en terminal:**

Bloqueo preventivo de contraseña y expiración de cuenta (sudo usermod -L -e 1 usuario_inactivo) o baja definitiva tras respaldar su información (sudo userdel -r usuario_inactivo), además de configurar inactividad máxima por defecto (sudo useradd -D -f 30).

https://drive.google.com/file/d/15Cq0XknmNL3iW-4GyT-I0T9icipUXEWw/view?usp=sharing

Actividad 4: Análisis de logs de seguridad

Objetivo: Obtener evidencia objetiva.

Comandos

- cat /var/log/auth.log | tail

o

- journalctl -xe

Tareas

Identificar:

- Intentos fallidos.
- Accesos sospechosos.
- Usuarios conectados.

last

who

Entregable

Reporte de evidencias en GitHub.

---

1. Fundamento Técnico y Propósito de los Comandos de Auditoría

En una auditoría de seguridad bajo la norma ISO/IEC 27001, las bitácoras del sistema operativo constituyen la fuente principal de evidencia objetiva para verificar el cumplimiento de los controles de acceso y detectar anomalías operativas:

2. Desarrollo de las Tareas de Identificación y Evidencia Objetiva

Tarea 1: Identificación de Intentos Fallidos de Autenticación

Los intentos fallidos permiten detectar ataques de fuerza bruta, adivinación de contraseñas o usuarios que intentan ingresar a cuentas para las cuales no tienen autorización.

- Comandos de inspección:
    - sudo cat /var/log/auth.log | tail
    - sudo grep -Ei "failed|failure|authentication failure" /var/log/auth.log | tail -n 15
- Evidencia identificada en los registros:
    - Entradas del módulo PAM como pam_unix(su:auth): authentication failure; logname=empleado uid=1003 euid=0 tty=/dev/pts/0 ruser=empleado rhost= user=administrador.

    - Mensajes de rechazo explícito como unix_chkpwd: password check failed for user (administrador) y FAILED SU (to administrador) empleado on pts/0.
- Interpretación del auditor: Se comprueba objetivamente que el usuario estándar empleado intentó cambiar a la cuenta privilegiada administrador sin conocer la credencial, quedando registrado el UID de origen, la terminal (pts/0) y la marca de tiempo exacta.

Tarea 2: Identificación de Accesos Sospechosos y Uso de Privilegios

Un acceso se considera sospechoso cuando ocurre fuera del horario laboral, proviene de una dirección IP no reconocida o involucra la ejecución de comandos administrativos por cuentas que no deberían realizar tareas de gestión.

- Comandos de inspección:
    - sudo journalctl -xe --no-pager | tail -n 25
    - sudo journalctl _COMM=sudo _COMM=su -n 20 --no-pager
- Evidencia identificada en los registros:
    - Eventos donde un usuario estándar intenta ejecutar comandos con sudo sin pertenecer al grupo sudoers: empleado : user NOT in sudoers ; TTY=pts/0 ; PWD=/home/empleado ; USER=root ; COMMAND=/usr/bin/cat /var/log/auth.log.
    - Aperturas de sesión administrativa (session opened for user root(uid=0) by administrador(uid=1001)) seguidas de modificaciones de permisos sobre los directorios corporativos empresa/finanzas y empresa/rrhh.
- Interpretación del auditor: El registro de systemd-journald permite rastrear con exactitud la trazabilidad de quién ejecutó cada comando privilegiado (USER=root, COMMAND=...) y bloquea los intentos de escalamiento no autorizados.

Tarea 3: Identificación de Usuarios Conectados e Historial de Sesiones

La revisión de sesiones activas e históricas permite contrastar si las cuentas conectadas corresponden al personal en turno y detectar sesiones huérfanas o intrusiones concurrentes.

- Comandos de inspección:
    - who (sesiones activas actuales)
    - last -n 10 (últimos 10 inicios de sesión registrados)
- Evidencia identificada en pantalla:
    - Con who: se observa administrador pts/0 2026-11-13 13:30 (192.168.1.15) y auditor pts/1 2026-11-13 13:35 (192.168.1.20), confirmando qué terminales están operando en vivo.
    - Con last: se visualiza la secuencia completa de sesiones (still logged in para las sesiones activas y el tiempo total de conexión (00:45) para las sesiones cerradas, además de los eventos reboot system boot del kernel).
- Interpretación del auditor: Permite verificar que no existan sesiones ocultas de cuentas inactivas ni conexiones simultáneas desde ubicaciones remotas no autorizadas.

3. Matriz Consolidada de Evidencias de Auditoría

Categoría Analizada	Comando Utilizado	Hallazgo / Evidencia Objetiva	Nivel de Riesgo	Acción Recomendada (ISO 27001)
Intentos fallidos	sudo cat /var/log/auth.log | tail	Múltiples eventos authentication failure y FAILED SU desde la cuenta empleado.	Medio	Configurar bloqueo automático de cuenta tras 3–5 intentos fallidos (pam_faillock).
Accesos sospechosos	sudo journalctl -xe	Intento rechazado de uso de sudo (user NOT in sudoers) sobre archivos restringidos.	Alto	Restringir el grupo sudo, aplicar principio de menor privilegio y alertar al administrador.
Historial de accesos	last	Registro de sesiones previas, reinicios del servidor y duración de conexiones por terminal.	Bajo	Revisar semanalmente /var/log/wtmp para detectar accesos fuera del horario laboral.
Usuarios conectados	who	Sesiones activas concurrentes en terminales pts/0 y pts/1.	Bajo	Configurar cierre automático por inactividad (TMOUT=600 en /etc/profile).

https://drive.google.com/file/d/1QVigXNxXeXpPKcx7MMaNSDyBvnanRaT8/view?usp=sharing

Actividad 5: Gestión de incidentes de seguridad

Objetivo: Aplicar el ciclo de respuesta.

Escenario

Un empleado descarga malware.

Trabajo por equipos

1. Definir:
2. Detección.
3. Contención.
4. Erradicación.
5. Recuperación.
6. Lecciones aprendidas.

Evidencia

Crear un documento:

- incidente_malware.md

Subir a GitHub.

Gestión de Incidentes de Seguridad

Objetivo: Aplicar el ciclo de respuesta ante incidentes de seguridad de la información. Escenario: Un empleado (empleado) descarga y ejecuta accidentalmente un archivo con malware (troyano/ransomware oculto en un adjunto de correo de phishing) dentro del servidor Linux corporativo.

1. Resumen Ejecutivo y Clasificación del Incidente

El incidente compromete la cuenta estándar empleado en el servidor Ubuntu Server de la organización, poniendo en riesgo la estructura de directorios corporativos (empresa/finanzas, empresa/rrhh y empresa/produccion).

2. Desarrollo del Ciclo de Respuesta a Incidentes

Fase 1: Detección

La detección temprana permite confirmar la presencia del código malicioso y acotar el alcance del compromiso antes de que escale a otros activos del laboratorio:

- Alertas de seguridad y síntomas en el host: El sistema antivirus/antimalware detecta una firma o comportamiento heurístico anómalo originado en el directorio /home/empleado, acompañado de un uso inusual de CPU y conexiones de red salientes hacia una dirección IP externa desconocida.

- Inspección de procesos y sesiones activas: El equipo administrador revisa qué usuarios están conectados y qué procesos se están ejecutando bajo el UID de empleado mediante los comandos who, last, ps aux | grep empleado y top.
- Auditoría de registros del sistema (logs) y red: Se examinan /var/log/auth.log, /var/log/syslog y journalctl -xe para identificar intentos de escalamiento de privilegios (sudo/su fallidos), además de auditar sockets abiertos con sudo ss -tulnp.
- Registro de la evidencia inicial: Se documenta la hora exacta del hallazgo, el nombre del archivo descargado y se calcula su huella digital criptográfica (sha256sum) sin ejecutarlo para preservar la cadena de custodia.

Fase 2: Contención

Una vez confirmado el incidente, se aplican barreras inmediatas para impedir que el malware se propague lateralmente por la red o afecte las carpetas de otros departamentos:

- Aislamiento de red a nivel de Firewall: Se bloquea de inmediato cualquier conexión saliente no autorizada o se desconecta temporalmente la interfaz de red del servidor mediante el firewall (sudo ufw deny out to any o aislamiento de la interfaz virtual) para cortar la comunicación con el servidor de comando y control (C2) del atacante.
- Suspensión de la cuenta comprometida y cierre de procesos: Se bloquea temporalmente el acceso del usuario afectado (sudo usermod -L empleado) y se finalizan todos los procesos activos asociados a su sesión (sudo pkill -KILL -u empleado).
- Blindaje de permisos mediante principio de menor privilegio (DAC/RBAC): Se verifica y corrige de inmediato cualquier permiso permisivo en los activos críticos (chmod 640 empresa/finanzas/planilla.xlsx, chmod 640 empresa/rrhh/empleados.csv y chmod 640 empresa/produccion/clientes.db), garantizando que la cuenta empleado no tenga permisos de escritura ni lectura fuera de su dominio de protección.
- Respaldo forense de bitácoras: Se realiza una copia de seguridad de /var/log/auth.log y del estado de los procesos para el análisis posterior del equipo auditor.

Fase 3: Erradicación

Con el incidente contenido, se procede a eliminar por completo el software malicioso y cualquier mecanismo de persistencia que haya intentado instalar en el sistema operativo:

- Eliminación de artefactos maliciosos: Se localizan y eliminan los archivos descargados recientemente por empleado en /home/empleado, /tmp y /var/tmp utilizando búsquedas por fecha de modificación (find /home/empleado -mtime -1 -ls) y escaneo antimalware (clamscan -r --remove /home/empleado).
- Revisión de mecanismos de persistencia: Se auditan las tareas programadas del usuario (sudo crontab -u empleado -l), los scripts de inicio (.bashrc, .profile) y los servicios del sistema (/etc/systemd/system/) para descartar puertas traseras (backdoors).

- Rotación de credenciales y actualización del SO: Se fuerza el cambio de contraseña de empleado por una contraseña robusta, se verifica que no existan cuentas huérfanas o inactivas en /etc/passwd, y se aplican todos los parches de seguridad del sistema operativo (sudo apt update && sudo apt upgrade -y).

Fase 4: Recuperación

Tras erradicar la amenaza, se restablecen los servicios de forma controlada verificando la integridad de la información antes de volver a producción:

- Verificación de integridad y restauración desde copias de seguridad: Se comprueba la integridad de planilla.xlsx, empleados.csv y clientes.db comparando sus hashes criptográficos (sha256sum) contra las copias de respaldo limpias. Si algún archivo presenta alteraciones, se restaura desde el último backup verificado.
- Reconexión gradual y desbloqueo de cuenta: Se restablecen las reglas normales del firewall (ufw), se desbloquea la cuenta del trabajador (sudo usermod -U empleado) con sus nuevas credenciales y se habilita la Autenticación Multifactor (MFA) para el acceso al servidor.
- Monitoreo intensivo post-recuperación: Durante las siguientes 72 horas se supervisan de forma continua los registros de autenticación (tail -f /var/log/auth.log), la actividad de red y la integridad de los directorios corporativos para confirmar que no existan reinfecciones.

Fase 5: Lecciones Aprendidas

El cierre del ciclo de respuesta permite retroalimentar el Sistema de Gestión de Seguridad de la Información (SGSI) bajo una estrategia de Defensa en Profundidad:

- Controles técnicos (Host y Red): Mantener actualizadas diariamente las firmas del antivirus, restringir la ejecución de binarios en directorios temporales (/tmp con opción noexec), aplicar estrictamente el modelo RBAC y el principio del menor privilegio (chmod 640 / 750), y reforzar el filtrado de paquetes salientes en el firewall.
- Controles administrativos y trazabilidad: Documentar el incidente en incidente_malware.md, actualizar la política institucional (politica_seguridad.md) prohibiendo la descarga de software no oficial y registrar todos los cambios en el repositorio de GitHub (git commit y git log --oneline) para garantizar la trazabilidad exigida por ISO/IEC 27001.
- Factor humano y concientización: Ejecutar sesiones periódicas de capacitación práctica para todo el personal sobre identificación de correos de phishing, enlaces sospechosos y manejo seguro de credenciales.

https://drive.google.com/file/d/1IaY0MZ3WZWDb9nvUF1zF9pVDZSP3AmuH/view?usp=sharing

Actividad 6: Control de cambios con GitHub

Objetivo: Comprender la trazabilidad.

Pasos

Crear repositorio:

- git init

Crear políticas:

- touch politica_seguridad.md

Realizar modificaciones.

- git commit -m "Version inicial"
- git commit -m "Actualización de política"

Revisar historial:

- git log --oneline

Pregunta

¿Cómo ayuda GitHub al cumplimiento de ISO 27001?

Actividad 7: Evaluación de riesgos

Objetivo: Aplicar metodología de riesgos.

Caso

Servidor Linux de la empresa.

Amenazas:

- Malware.
- Acceso no autorizado.
- Pérdida de energía.
- Error humano.

Trabajo

Crear matriz:

Activo	Amenaza	Impacto	Probabilidad	Riesgo

Guardar en:

- matriz_riesgos.xlsx

Subir a GitHub.

Evidencia:

Matriz riesgos

Actividad 8: Auditoría completa tipo Lead Auditor

Objetivo: Simular una auditoría real.

Equipo Auditor

Debe revisar:

- ls -l
- cat politica_seguridad.md
- last
- who

Equipo Auditado

Debe proporcionar evidencias.

Entregables

- Plan de auditoría.
- Lista de verificación.
- Hallazgos.
- Informe final.

Todo gestionado mediante Issues y repositorios de GitHub.

---

1. Introducción

La presente actividad consiste en la simulación de una auditoría de seguridad de la información sobre un servidor Linux de una empresa ficticia, tomando como referencia los controles de ISO/IEC 27001:2022.

2. Objetivo

Evaluar los controles de acceso, la administración de usuarios, la documentación de políticas y la revisión de registros de seguridad.

3. Alcance

La auditoría comprende los directorios de finanzas, recursos humanos y producción, además de las cuentas de usuario y los registros de autenticación del servidor Linux.

4. Metodología

Se consideran los siguientes procedimientos de verificación:

- `ls -l`: revisión de permisos de archivos.
- `cat politica_seguridad.md`: revisión de la política documentada.
- `last`: consulta del historial de sesiones.

- `who`: identificación de sesiones activas.

5. Hallazgos

Se identificó durante la actividad de permisos una configuración inicial `777` en archivos sensibles de finanzas y recursos humanos. Posteriormente, se aplicó una configuración `640` como medida correctiva.

Adicionalmente, se consideran los escenarios simulados de contraseñas compartidas y usuarios inactivos sin deshabilitar, previamente desarrollados en la actividad 3.

6. Acciones correctivas recomendadas

- Mantener permisos restrictivos sobre los archivos confidenciales.
- Implementar cuentas individuales para los trabajadores.
- Revisar periódicamente las cuentas de usuarios inactivos.
- Documentar y aprobar las políticas de seguridad.
- Supervisar los registros de autenticación y accesos.

7. Conclusión

La auditoría simulada permite identificar deficiencias en la administración de accesos y proponer medidas preventivas y correctivas orientadas a fortalecer la seguridad de la información.

La evaluación definitiva del cumplimiento requiere completar la revisión de las evidencias y verificar la implementación efectiva de los controles.

Proyecto Integrador Final

"Auditoría ISO 27001 de una Empresa Simulada"

Los estudiantes deberán:

1. Crear una infraestructura en Linux.
2. Configurar usuarios y permisos.
3. Documentar políticas.
4. Registrar evidencias.
5. Gestionar documentación en GitHub.
6. Ejecutar una auditoría.
7. Emitir informe final con hallazgos y acciones correctivas.

Esta metodología permite que los estudiantes practiquen simultáneamente:

- Linux.
- Git y GitHub.
- Evidencias de auditoría.
- Gestión documental.
- Análisis de riesgos.
- Elaboración de informes ISO 27001 Lead Auditor.